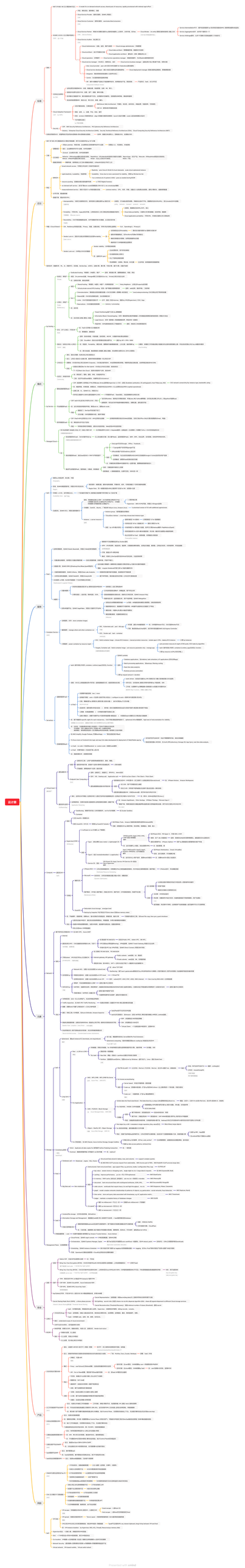

云计算

- 标准
  - 架构
    - NIST SP 800-145 云计算的NIST定义 — A model for on-demand network access, shared pool of resources, rapidly provisioned with minimal mgnt effort
    - ISO/IEC 22123-3 云计算参考架构 2023 旧-17789
      - 术语、角色活动、服务模式、功能
      - Cloud Service Provder：提供云服务，如AWS, 阿里云 CSP
      - Cloud Service Customer：使用云服务，user/subscriber/consumers CSC
      - Cloud Service Partner：帮助CSC部署云服务 by 提供咨询服务, 上云软件、分析市场，如Tata CSN (Service Broker) — Cloud Broker：An entity 管理云服务的使用, 性能, 交付 CSC与CSP的协商中间人
        - Service Intermediation中介：提升给定的服务 by 优化特定功能(如IAM) / 提供附加服务(如监控)
        - Service Aggregation合并：合并多个服务为一个
        - Service Arbitrage套利：从多个代理商 灵活挑选服务 》形成多云
      - Cloud Service Auditor：独立第三方 CSA
      - •
        - Cloud Administrator：实施、监控、维护云服务 — Cloud storage administrator：存储管理
        - Cloud architect：设计开发解决方案
          - Cloud data architect：管理数据存储、数据各方向流转
          - Cloud application architect：重构/改 - 迁移- 部署应用上云
        - Cloud operators：日常操作 — Cloud service operations manager：准备系统操作、为云和admin服务提供支持
        - Cloud service manager：CSC员工 - 商务协议、谈价 — Cloud service business manager：监督业务计划,计费,客户关系、财务交易
        - •
          - Inter-cloud provider：peer with 其它CSP/云服务 for federations(联合服务)
          - Cloud service developer：建立+验证云服务(应用,基础架构) — Cloud deployment manager: 收集云服务监测指标、管理部署流程
          - Integrator：整合现有的系统/服务入云的甲方员工
          - Carrier：为云服务提供连接和传输
          - ISP：制作+销售的产品独立于底层硬件和OS，如网络安全产品、预定系统 Independent Software Vendor — 产品形式：SaaS、永久许可证
    - 云安全企业架构 by CSA
      - 业务运营支持服务BOSS：合规、数据治理、风险管理、法律、HR、审计…
      - 信息技术运营与支持 ITOS：变更、资产、配置、事件/问题…
      - 技术解决方案服务TSS：展示层服务(用户交互)、应用服务(代码编写)、信息服务(DB存储)、基础架构服务
      - 安全和风险管理SRM：身份认证、审计日志、渗透、漏扫…
    - Cloud Adoption Framework CAF by CSPs
      - 云技术最佳实践、工具和指引
        - AWS/Azure Well-Architected：可靠性、安全性、成本优化、卓越运营、性能效率、可持续性
        - CAF-AI：使用AI技术的最佳实践
      - 领域：业务、人、治理、平台、安全、操作
      - 阶段：envision 识别转型机会 – align 识别能力差距和依赖项 – launch 试运行调整 – scale 以适当的规模正式运行
      - *OCF通用云接口 by 开放互联基…
    - Security
      - CSP：AWS Security Reference Architecture、MS Cybersecurity Reference Architecture
      - Industry：Enterprise Cloud Security Architecture (SANS)、Security Technical Reference Architecture (CISA)、Cloud Computing Security Reference Architecture (NIST)
  - 标准合同条款SCC：欧盟两类示范合同(EU控制者>非EU控制者/处理者) — GDPR：数据主体(使用人)、控制者(CSC)、处理者(CSP)
- 迁云
  - NIST SP 500-293 美国政府云计算技术路线图：用于迁云前的评估 by 10个步骤
  - 方案
    - 部署类型
      - 本地on-premise：传统方案、企业拥有自己的软硬件和许可+运维 — 初期投入大、可定制化、本地控制
      - 宿主：企业拥有软件许可+运维、CSP负责硬件
      - 云cloud：企业每月付费、CSP负责软硬件
    - 迁云类型 — Refactor - lift&reshape重构,如改成云原生、Rehost - lift&shift(直接迁移)无改动、Replatform - lift,tinker&shift变部分功能为云服务、Retain - 无法上云则云作为附加、Repurchase - 买云产品、Retire -下线、Relocate - lift&optimize更适合云的改动、
    - 数据迁移类型 — 聘请专家、使用现成上云工具-改数据,如格式、Lift&shift无改动,不利于上云
  - 特征
    - BRROM
      - broad network access：可用区分布全球 》各地可快速访问
      - rapid elasticity / scalability：快速伸缩
        - Elasticity：auto Grow & Shrink for burst demands，scale-in/out ephemeral instance
        - Scalability：Grow due to more users/work for stabiltiy，控制 by SKU/service tier
        - *run a minimal set of systems in BAU - grow as needed during BCDR
      - resource pooling：资源的合理分配和循环利用 — x: 不利于digital forensics
      - on-demand self-service：自行扩展auto-scale资源配置 (CSP少涉入) via console/api/编程
      - measured/meterd service：用多少花多少 vs 传统闲置也花钱 — common metrics：CPU、内存、存储、流量(云入站免费出站收费)、虚拟计算时长、函数调用数量
    - 水平扩展：增加服务器
    - 垂直扩展：增加内存/CPU…
  - 考量 < Cloud Shared
    - Interoperability：与其它云服务的交互、组件的拆分,重组,复用 by 指定方式 互操作性 — 合规性、行为(输出是否如期)、传输协议(如HTTPS)、数据格式(如JSON,XML)、语义(model,如VM,容器) policy behavior transport syntactic semantic
    - Portability：不同CSPs、legacy和云环境、公有和私有云 之间 迁移应用及其数据(非组件) 可移植性 防vendor lock-in
      - 合规性、数据格式(如XML,OVF)、语义
      - Cloud data portability：云服务之间 移动数据，如块存储、数据库
      - Cloud application portability：不同CSPs、本地和云服务之间 迁移应用
    - Reversibility：CSC可取回数据和应用、CSP可删除所有CSC数据、从云回迁至本地 可逆性
    - CIA、Resiliency(失败容忍度)、Privacy、性能、治理/合规、可审计性(问责性,追溯性) — SLA、OperatingLA、PrivacyLA
    - Vendor Lock-in：因技术/法规/合同限制无法实现Portability Data Lock-in — 防
      - 合同条款应允许Portability — ！要求支付额外费用 for 阻碍CSC换CSP
      - 避免专用数据格式、如Terraform(开源IaC专用格式)
      - 确保无物理/技术限制、如带宽/数据导出功能
      - 确保有多个CSP能够满足监管要求
    - Vendor Lock-out：CSP阻止CSC访问数据
      - Vendor viability：CSP倒闭/被收购
      - 防：选择CSP upon
        - 企业经营时间，但IT多变也难说
        - 在云服务的核心竞争力
        - 对上下游供应商的依赖
        - 司法管辖权：注册地、营业地、DC位置 — 立法环境：如英国脱欧变数据跨境
  - 相关技术：数据科学、ML、AI、深度学习、区块链、DevSecOps、IoT/ICS、边缘计算、雾计算、可信计算、量子计算、后量子加密
- 模式
  - by Hosting
    - 私有云：单用户 Private
      - Dedicated hosting：1物理机 - 1/N虚机 - 1客户 — 适用：高性能计算、重要数据备份、网游、网站
      - 类型：On-premises自建、Managed第三方托管(DC/co-lo)、Virutal公有云内划分出来
      - 劣：远程访问难、建设运维贵
    - 公有云：多租户 Public Multitenancy
      - 类型
        - Shared hosting：1物理机 - N虚机 - N客户 - 共享物理资源 — ！Noisy Neighbors：占用过多capacity的邻里
        - Virtual private server(VPS) hosting：区别 – 客户限额分配物理资源 — 适用：web应用、测试环境、二级存储
      - SLA
        - Oversubscription：售卖超出实际容量的容量 > CSC互岔高峰 > 更赚钱 =航空座位 — *over/underprovisioning: CSC买高出/低于需求的容量
        - Shares份额：CSC优先资源的加权，当云资源匮乏时
        - Limits：CSC可获的最多资源水平 — 水平：固定 / 变动=borrow、配额 by VM(非hypervisor) / CSC / App
        - Reservations：CSC的最低资源保障 — memory + processing
      - 优：成本低
      - 劣：自主性低 (定制, 管控) +风险
        - Tenant Partitioning(租户分区) by 逻辑隔离
        - Information Bleed / Eavesdropping：在同一基础架构处理/存储数据 > 京东数据/进程情况被淘宝探测 = 旁路/CC攻击
        - Legal Seizure：在同一服务器 > 淘宝数据被扣押，牵连京东一起被扣
        - 利益冲突：CSP运维淘宝的员工不能碰京东 — 提权：淘宝员工未经授权看京东
    - 多云：多个公有云 - 不同CSP Multi
      - 如：FaaS+云存储+云大数据分析
      - 劣：管理复杂、通信延迟
    - 混合云：私有云/本地 +公有云 Hybrid 常用
      - 适用：自动化制造、内容创建、实时游戏、AR/VR、大数据本地处理\远程备份
      - 工具：CloudBolt - 混合云成本管理和资源治理平台 — 通信 by API + VPN + WAN
      - 优：低延时、Portability、满足合规、重要操作/敏感数据自留、上云过渡、临时高峰 by — 云爆发：突增的工作负载(促销/大数据分析)达到内部资源的上限 - 手动/自动切换公共云 by LB重定向请求 cloud bursting
      - 劣：更大攻击面、集成更复杂 (如编排, 通信, 数据)、安全更难 (如跨云AA, 无中心化管控)
    - 分布式云
      - 演化：混合云局限 - 私有云和公有云差距拉大
      - 定义：公有云+混合云+边缘计算，服务所有权和管理统一归公有云CSP
      - 部署地：CSC的本地公有云(如AWS Outposts)、CSC就近城市的DC、5G运营商的移动网络、物联网设备/边缘设备、全球网络边缘(如PoP,CDN)
      - 阶段
        - 类混合云模式like-for-like-hybrid：CSC独占分布式云资源，犹如私有云
        - 下一代云Next-Gen Cloud：资源与邻居用户分享，犹如WiFi
    - 社区云：多组织共享 Community
      - 如：跨区部门、警局、医院、学校、在线游戏平台
      - 工具：社区平台(较SaaS复杂)，如建筑社区CoConstruct
  - by Service
    - 基础设施即服务IaaS
      - CSP -底层硬件, 如网络(L3 FW),存储(wipe drives),服务器,Hypervisor ‖ CSC - 运维, 如validate sanitization, OS setting/patch, Host FW/access, NSG — CSC network connectivity By: instance type, bandwidth, sizing
      - 优：缩放网络、共享资源、按需自主、本地资本性支出CAPEX > 云上运营性支出OPEX (capital>operational)
      - 运维工具：CL，如AWS CLI、阿里云CLI
      - 软件定义数据中心SDDC/虚拟数据中心VDC — = IT即服务ITaaS：与IaaS类似，为促进销售多出来的分类
    - 平台即服务PaaS
      - CSP -IaaS+OS,运行时,中间件 ‖ CSC - 开发
        - *运行时Runtime：程序运行所需的资源，环境(Java JRE, Python解释器) - 含代码,库,依赖,文件,I/O… / 库(python内建库sys)
        - 选购差异：有无运行时环境(影响编码承载性)、部署位置、虚机是否开放
      - 优：运行多语言多框架多环境、降低lock-in、提高auto-scale
      - 风险
        - 遗留后门：DevOps开发后留下后门
        - 交互问题：CSP定期更新OS后、程序不兼容
    - 软件即服务SaaS
      - CSP -PaaS+IAM,应用安全 ‖ CSC - IAM,应用安全,数据 — 应用程序按需在线访问(Web浏览器)、支持订阅(Office 365)/付费/免费服务(Gmail、网盘)
      - 优：降低成本(许可证,IT支持)
      - 风险 — 专有格式降低可移植性、虚拟化对应的风险、Web应用/API对应的风险
  - Managed Cloud
    - 将 非业务操作 (如监控, 安全, 补丁, 备份) 托管 CSP 托管服务提供商MSP — 如 网络运营中心NOC + Helpdesk服务 = 远程监控 + 主动管理 | 托管整个infra + CSC仅负责监控日志
    - 如
      - 安全即服务SECaaS：为CSC维护安全 by 托管安全服务提供商MSSP — 云上安全解决方案：防火墙FWaaS、监控即服务MaaS、SIEM、IDPS、安全边界、访问控制、EDR/EPP/MDR/XDR…
      - 身份即服务IDaaS：类似SaaS的SSO + PAM"JIT特权提升"
        - 如
          - OneLogin可访问Google、Office、Facebook…
          - 一个google账户访问所有google产品
          - Office365账户访问OneDrive上的文件
        - 组成
          - 目录集成：与企业的目录服务(AD/LDAP/云目录服务Google G Suite)实时同步用户信息
          - 应用集成：接管各SaaS的身份验证功能
        - 劣：关键的身份管理IdM功能被外包 = 监管问题、重要数据泄漏风险变大
      - 集成平台即服务IPaaS、服务集成、云集成、系统集成
        - 旨在：无缝连接本地和云上资源
        - 服务集成：+ 消除数据孤岛、处理可见性；SDDC的一种
- 服务
  - IaaS
    - 地理 by 合规边界，如北美、中国 Geography
    - 区域，如AWS美国西部1区、阿里云华东1区(杭州) Region
      - 各区差异：地理位置、服务内容和规模、开服时间、成本、可用区数量 》可多区域架构部署
      - Region Pairs：同一地理的相距≥300公里的两个区域 for DR，如西部+北部
    - 可用区 = ≥1 DC，如可用区I,H,G… Availability Zone 用户可选 — 一个区域的可用区*N / 服务器分别部署不同可用区 for 冗余\扩展
    - 云虚拟机，如AWS EC2、阿里云服务器ECS
      - 架构：网络基础设施 [公有IP ~ DC内部网络 [弹性网卡*N]] ~ 计算集群 [宿主机 [云虚机[CPU,内存]]*N] ~IO线路~ 存储集群 [存储服务器 [云硬盘]*N]
        - ！计算存储分离
        - Hypervisor：AWS-KVM(开源)、阿里云-XDragon(自研)
      - OS镜像：CentOS、Ubuntu、厂商自有*(Aliyun Linux, Amazon Linux) — *customized version of OS with additional agents/tools
      - Instance：a server resource 实例
        - Instance group：相同配置的实例集合
        - *CloudZero Advisor：a tool help choose best instance type
        - 类型：by vCPU数:内存比
          - 通用均衡型 1:4=2核8G — 计算密集型 1:2 for 视频编码
          - 内存优化型 1:8 for 大数据分析 — 图形计算型 for ML
          - 本地存储型 for 高性能/大容量，如并行计算[Hadoop集群+ MapReduce/Spark]
          - 突发性能实例 for 成本+解决闲置资源：积分制 - 随时间匀速累加+随使用消耗
          - 抢占式实例 for FaaS：使用闲置、非预留的计算资源 Preemptible instance
  - PaaS
    - 应用托管服务，如AWS Elastic Beanstalk，阿里云 Web应用托管服务
      - 隔离用户打包部署的应用 by Docker/虚机
      - APM：CPU利用率、响应时间、错误率、交易跟踪(事务调用)、实例运行数量、请求数、正常运行时间、内存使用率、并发连接数 应用性能监控
      - 扩展：垂直/水平=弹性伸缩
      - 集成：对接云上DevOps组件(如GitHub代码仓库)、云监控系统等
    - - 轻量/建站类服务，如阿里云 轻量应用服务器 — 自动分配服务器、安装环境、开放FTP端口…
    - 大数据计算，如AWS EMR (含Hadoop,Hive,HBase,Spark等组件)
      - 动态创建计算集群 + 解耦传统大数据的计算和存储 by 对接OSS对象存储服务
      - 增值：+Jupyter Notebook开源工具 for 快速与集群交互
    - - 无服务器查询服务，如AWS Athena、阿里云Data Lake Analytics — 即查即用对象存储中的数据，按读取的字节数收费
    - - 分析型云原生数据库，如AWS Redshift、阿里云AnalyticDB — 基于MPP架构，高压缩比的列式存储 + 分布式并行查询处理
    - 日志服务 vs 传统 - ELK技术栈搭建一个日志存储和分析系统 Elasticsearch+Logstash+Kibana
    - AI服务
      - 内置AI服务
        - 非结构化数据处理分析 by 调用对应的API和SDK — 如阿里云 人脸口罩检测API
        - 计算机视觉 - 人脸识别、物体检测、OCR…
          - 文本自然语言处理NLP - 舆情监测、用户评论分析
          - 语音类智能服务/语音合成 – 音频与文字的互转，如AWS Amazon Polly
          - 视频内容分析 - 监控视频分析、用户内容审查，如AWS Rekognition
      - 自有AI构建平台，如AWS SageMaker、阿里云 机器学习平台PAI
        - 实现全生命周期的模型构建 — vs 传统 – AI构建信息和模型分散管理、训练资源紧张等
        - 数据准备和标注：数据集存于对象存储 – AI构建平台提供标注功能的门户网站
        - 模型训练：内置ML/DL算法+集成开源算法
        - 模型部署/推理：内置模型调用方法 inference
  - Container Service AWS
    - 仓库服务，ECR：store container images
    - 编排服务：manage where and when containers run
      - EKS，Kubernetes aaS：pod – k8s app 开源
        - 半托管：虚机+K8s编排服务 — 优：CSP提供Master节点、CSC仅建Worker节点
        - 扩展：集成各类IaaS,PaaS组件，如引导外部流量的AWS ALB Ingress Controller
      - ECS，Docker aaS：task – container AWS生态
    - 计算服务：power container by resource mgmt
      - EC2：Build container image – choose EC2 instance – manual provision resources – isolate app in VMs – deploy EC2 instance — 计费 by instances
      - Fargate, Container aaS：Build container image – set resource parameter only – manage app 无服务器容器(实例)服务
        - auto provision resouces & mgmt of EKS pods / ECS tasks by algorithm
        - IaaS+ 操作系统,中间件, container ‖ runtime, app(无状态), function
        - 计费 by resource (vCPU,内存,存储…)
  - Serverless
    - 函数即服务FaaS
      - IaaS+ 操作系统,中间件, container, runtime ‖ app(无状态), function
        - 如AWS Lambda
        - 适用
          - Stateless applications，如chatbots, task schedulers, IoT applications (饮料点单app)
          - Batch processing applications，如backups, filtering, sorting
          - Real-time data analytics
          - Business process automation
        - 计费 by request amount + duration
      - 流程：CSC云上新建函数实例+写代码 - 选择函数触发方式 - 底层资源自动分配
        - event-driven：自动运行函数 by API/ 消息队列/ 对象/ 定时触发器 (CSC选择)
        - 对外交互：访问如DB, 消息队列等外部存储 by 丰富类库、SDK
        - 工作流：处理事件 by 解耦函数+流程组装 via 配置文件/图形化UI 如AWS Step Functions、阿里云 函数工作流
      - vs PaaS
        - 对部署环境的控制：less | more
        - 应用的扩展性：auto + 无实例~实时扩展 (水龙头) | configure to auto + 请求CSP分配资源 (饮水机)
        - 价格：精确收费 by 调用时长,调用次数 (实际水量) | 由CSC预估by 月 (饮水桶) pay-as-you-go
        - 启动时间：服务调用=秒级冷启动 | 非秒级 + 部分功能需保持后台运行(否则不操作=断进程=影响用户体验)
        - 工具集：标准函数模板 | CSP提供完整开发测试工具
        - 边缘计算能力：部署不依赖平台=可紧邻终端部署=缩短延迟 | 本质跑在IaaS=部署在云计算设备/云数据库
      - 优：基于微服务=specific rights for each role/service、CSC不用处理底层架构的补丁、ephemeral infra=难被破坏、high level of instrumentation for visibility 仪表盘instrumentation：函数运行指标 日志 时间等在Dashboard的可视化
      - 劣：冷启动：无函数请求时休眠, 启动延时 > 不适合不间断运行的应用
        平台限制：内存, 函数运行时长, 并发数上限 < 合理规划资源
        高依赖性：架构绑定供应商 < 自行隔离api网关和DB(难) / 使用第三方技术框架
    - 后端即服务BaaS
      - 如 AWS Amplify, Google Firebase, 开源Back4app — *移动设备后端 MBaaS
      - To focus more on frontend & biz logic and easy full-stake development & deployment of Web/Mobile app by
        - 无代码开发平台NCDP：完全不需要撰写代码，类似乐高编程
        - 现成后端功能in API/SDK，如 Auth (MFA,directory), Storage (S3, App Sync), real-time data analysis…
      - vs CaaS：no code + 完全的backend vs custom code + 容器化web服务
      - vs FaaS：非事件驱动 + 无自动扩展 vs 是+有
      - 劣：高度依赖CSP、定制需求受限
- 元素
  - Virtual Asset 虚拟资产
    - 虚拟桌面VD
      - 类型
        - 远程访问工具：让用户远程控制桌面的显示、鼠标、键盘…
        - 虚拟软件的扩展：封装多个应用+某种形式的桌面/壳 — > 跨OS使用
        - 扩展桌面：屏幕容纳多个应用 - 鼠标切换
      - Endpoint User Computing EUC
        - 适用：远程员工、派遣员工、呼叫中心、demo\培训
        - 技术：VDI、Desktop aaS、Application aaS — 连VDI via Zero Client < Thin Client < Thick Client
        - 虚拟桌面基础设施VDI/环境VDE
          - 服务器划分成VM - VM托管VD - 员工使用个人设备远程访问(local/cloud) — 如：VMware Horizon、Amazon Workspaces
          - 类型
            - 永久VDI：用户可保留自定义桌面
            - 非永久VDI：所有用户相同桌面(无论操作 登出后还原) = 静态系统
          - 虚拟移动基础设施VMI：VDI的Android版 - 用于BYOD/COPE/CYOD
    - 虚拟软件/应用 vSoftware/App
      - 演化：应用与OS不兼容 / 应用间冲突 》虚拟打包环境 彻底隔离应用 = 应用运行在沙箱内+与OS不交互 — 优：跨OS - 如Win应用运行在Linux上
      - 应用程序流：无需本地安装-直接使用-应用资源相互隔离 = 瘦客户端 Application Streaming
        - 如：Amazon AppStream、Citrix XenApp、VMWare ThinApp、Microsot App-V
        - *瘦客户端：有限功能(显示/键盘/触屏等)或虚拟接口的电脑/移动设备 - 用于访问大型机/VM/VDI/VMI thin client
      - •
        - Sandboxing：隔离开发代码 / 分析恶意软件，not for与OS隔离 — 如 Zscaler Sandbox
        - Container
  - Compute — 虚拟机VM IaaS
    - 组成
      - 主机 HostOS = 物理机OS
      - 客机 GuestOS = VM OS — 管理 by GuestOS Toolsets
        - 如VMWare Tools、Amazon 准虚拟驱动程序(适用Windows实例)
        - 功能：改善虚拟OS by 映射存储、优化网络、视频输出、音频、输入
    - Hypervisor/VMM VM Monitor
      - A software to run N*虚机 on 1*物理机
      - 类型
        - Type I：原生/裸机 bare-metal + a lightweight OS
          - VM1[GuestOS~App] | VM2 | VM3…
VMM (驱动=管理器)
硬件
            - 如VMware ESXI、MS Hyper-V、开源 XEN > KVM
            - 商用：生产, QA, 负载测试 — 适用：资源优化(N业务无需N物理机)、桌面虚拟化for远程访问
            - 虚拟化管理平台：VMware vSphere — 保护 by 隔离虚拟化管理网络与客户环境
          - 优：运行在硬件上=高效、安全(依赖VMM) — 劣：驱动管理、贵
        - Type II：宿主 hosted/embedded + a application
          - App1 | VM[GuestOS~App2] | App3…
HostOS~VMM(环0) | ULM(调驱动)
硬件
            - 如VMware Workstation、Oracle VirtualBox
            - 私用、运行旧程序、作为隔离沙箱
          - 优：运行在OS上=用户友好、借用HostOS驱动 — 劣：依赖HostOS=低效, 攻击面大
        - Service OS：混合 — VM (Guest OS~App) | Service VM (Service OS~驱动)
Micro Hypervisor
硬件
    - 可用性
      - 集群主机
        - VMware ESXi — 分布式资源调度DRS：在物理和VMs之间的抽象层资源池 - 向VM自动分配物理资源 + 维护模式 Distributed Resource Scheduling — VMotion技术：手动调配资源
        - Microsoft — 动态优化：分析实时数据(流量,负载)+目标 - 调整资源 Dynamic Optimization
        - 维护模式：VM1进入维护模式 - 负载分至VM2 - 维护完毕 - VM1回到资源池 - 负载平均分配 Maintenance Mode
          - 进入前准备
            - 从系统/设备中移除任何运行中的实例 < 防影响PROD操作
            - 防用户登录
            - 确保日志继续 (尤其特权日志)
          - 迁移
            - 冷迁移：VM关机后进行
            - 热迁移：完整保存VM运行状态 - 快速恢复到原/不同的物理机 - 用户无感知 Live
            - 脏页数据：热迁移中不停机 - 业务程序产生新的数据 > 脏页速率不可大于迁移带宽
      - GuestOS
        - Redundant cloud storage：zone/geo level
        - Backup by Snapshot *电子取证(不可shut down 否则lose memory state)
    - 优：节省硬件、差错抑制、保障QoS、强大的调试与性能监控、移植性高、临时计算 — 可装额外虚拟化工具，如Guest file copy, time sync, guest shutdown
    - 安全
      - 虚拟机自省VMI技术：通过安全检测(物理地址、网络配置、OS等) 确保基线未被篡改
      - 敏感VM单独部署物理机、加密VM快照、底层硬件加密启动、配置定期审阅
      - 默认关闭inter-VM网络通信
  - Network
    - 基于软件定义网络SDN — 如 AWS VPC、Azure AHET
    - 架构
      - Internet
      - 虚拟私有云VPC：CSC自建的私有网络VLAN，可多个 与可用区：纵横关系
        - 如 路由器 192.168.0.0/16 — 如划分Public VPC、Admin VPC、DB VPC…
        - VPC互联(by对等连接Peering)、VPN连接等，如AWS Transit Gateway, 阿里云云企业网
        - 本地DC连VPC (by VPN/专线)，如AWS Direct Connect, 阿里云IDC专线
      - 子网Subnet：VPC内设子网 by 云交换机*N private/public 可跨可用区
        - 如 交换机 192.168.1.0/24、192.168.0.0/24
        - Internet gateway, API gateway
          - Public subnets：web前端、LB、堡垒机
          - Private subnets：web后端、DB、内网服务器
        - 弹性网卡ENI：即VM网卡。VM*1 = 主网卡(对应子网)*1 + 辅助网卡(动态解绑)*N
      - 访问控制 by
        - Network ACL：设置入站/出站规则 at subnet level
          - 如：allow TCP 3389
          - Geofencing：基于user's geolocation限制访问 by GPS/RFID/IP/Wi-Fi/蜂窝 > 识别可疑访问 / 授予访问权限 / 当设备离开指定区域时告警
        - 网络安全组NSG：设置入站/出站规则 at VM*n level — = Virtual FW
        - 应用安全组ASG：设置入站/出站规则 at one VM — 拓扑：subnet[VM1 ~ASG | VM2 ~ASG] ~NSG | Internet — Zero trust by NSG+ASG = 比传统容易
      - 内外访问 by 子网
        - 弹性IP：可动态解绑的固定+公有IP — 适用少量VM之间双向
        - NAT网关：创建网关实例 – 绑定弹性IP – 创建源/目的地址转换(SNAT/DNAT)条目 [选择交换机] – 交换机对应子网的虚机共用弹性IP 》实现内外访问 — 适用大量VM之间双向
        - 负载均衡LB：NAT网关 +流量分发
          - 适用大量VM被用户访问
          - *LB通常将源IP改为自身IP - 避免内外直接交互
    - 安全
      - 与传统区别：企业一旦上云(多租户)，无法在网络边界部控
      - Traffic inspection，如 AWS VPC Traffic Monitoring — 检测比传统难 < 流量至VM NIC=难以混杂模式抓流量
      - 蜜罐：部署Dark/"闲置"公网的成本↑ < 云对公有IP收费
      - 漏扫：传统工具 / CSP服务，如Azure Defender, Amazon Inspector
        - SaaS/PaaS多不允许扫CSP设备
        - IaaS允许扫其部分：如Amazon - 实例, NAT网关, 弹性负载均衡器, API网关, Lambda函数…
      - 堡垒机/跳板服务器：远程访问(RDP/SSH)~ 堡垒机(公有子网) ~跳转访问系统(私有子网) Bastion Host / Jumpbox / Jump Sever +NSG使用
        - RDP：多因素验证+帐号锁定策略
        - SSH：多因素验证+SSH证书
        - *Virtual Client：一个远程连接VM的软件；适用BYOD
      - 安全终端访问 / 基于控制台的访问机制：关注对终端的物理访问 Secure terminal access Console-based access mechanisms
  - Storage
    - IaaS
      - Ephemeral：随IaaS instance兴亡(terminate, not stop/reboot) 临时
        - 如 C:盘、硬盘缓存(如SQL Server的Buffer Pool Extension)
        - Ephemeral computing：短时间调配资源auto-scaling by 快速启动/关闭VM PaaS 易于 IaaS
      - Long-term 长期
        - Raw：a LUN on a SAN 裸盘
          - 本地磁盘：即宿主机磁盘，for 本地存储型云虚机(适用高性能并发计算)、临时存储 — 如 硬盘、SSD
          - *by Layer
            - 原始存储 = 物理硬盘
            - Raw Disk：裸盘 - 初始化 + partition/设置文件系统 后使用
            - Partition：直接面向user的drive，配置volume by Windows - 盘符 如(T:)、Linux - 路径 如sdd /test 分区
        - For Application-
          - -NAS – NFS | SMB – NFS | SMB File Server 文件 Azure Files AWS EFS
            - find file by path — 父文件夹 - file1.txt | 子文件夹 - file1.txt；改文件=改整个txt；层级结构 — 格式
              - 本地 - FAT32/NTFS/EXT4 — 集群 - vmfs6/gfs2
              - 分布式：moosefs/cephfs 无集中磁盘 有N*服务器磁盘
            - for human access/sharing
            - 类型
              - Server based：本地文件服务器 – 固定容量
              - Scale up：控制器+驱动器 – 扩容 by 购买NAS drives + 达上限时购买一个新设备、但皆为孤岛 纵向
              - Scale out：一组服务器 – 扩容 by 增加逻辑单元 横向
          - -SAN – FC/iSCSI - Block Storage 块 Azure Managed Diska AWS EBS
            - divide data into fixed-sized block - find data block by a unique LBA(逻辑块地址)/block no. — 硬盘 - 分区*n - 分块*n*m (62块=file1.txt)；改文件=改块#2-5；块结构
            - for SSD/HDD、VM/DB《 IOPS性能高
              - 性能衡量by IOPS(每秒读写次数 by 类型+容量)、吞吐量、访问延时等
              - iSCSI SANs RAID
            - 云硬盘
              - 类型
                - 基于传统HDD：低性能低成本 — 结合HDD和SSD：常用
                - 基于SSD：关键应用\DB — 高性能SSD：SAP HANA高性能计算平台, 高并发OLTP数据库
              - 特征：挂载虚机的虚拟块级存储、云新盘热挂载=易扩容、Hadoop分布式文件系统HDFS=高并发访问但不适用小文件处理
          - -Object – Restful API - Object Storage 对象 Azure Blob Storage AWS S3
            - find object by a UID + metadata in single repository (Key-value形式) — Blob: Binary large objects
            - for 类似私有网盘、虚拟镜像/图片/文件对象
            - 特征：无限扩容(PB级)by加存储节点、分布式存储节点/服务器、自动在多个位置复制数据=冗余、按使用量计费
              - 加密 by IRM、App层面
              - 无runtime环境=不易被virus感染
        - For 归档/备份，如 AWS Glacier, Azure Archive Storage, Google Coldline
          - 存储分层 by 访问频率，如"hot, cold, archive" — 生命周期管理：设置规则自动清理/降级、版本回滚
          - 性能 by data access patterns, retrieval time
    - Consistency类型 一致性 IaaS/PaaS
      - Strict：duplicate all data copies for 读写操作 before finalizing transaction — 优：一致性高
      - Eventual：数据变更最终植入所有副本 via 异步传播 — 优：replica少
    - PaaS
      - Databases aaS — Relational：engine - SQL, Oracle
        - Structured Data stored in tables, rows, and columns — support complex queries
        - 如 AWS RDS-OLTP-process request from web/mobile、AWS Aurora-part of RDS、AWS Redshift-OLAP-process large data
      - Big Data aaS — Non-relational
        - Unstructured / Semi-structured Data：app support files, e.g. pictures, media / configuration files, logs — OLTP/OLAP
        - 类型
          - key-value：session stores or shopping carts，single-digit ms r/w + large data & requests — 如 AWS DynamoDB, Redis
          - caching：improve performance，µs r/w + 写入不存=ephemeral — AWS ElastiCache
          - in-memory：RAM cache, 实时出价, 游戏排行，sub-ms r/w + 持续写入=durable — AWS MemoryDB
          - document：Semi-structured Data with multilayered attributes, JSON, XML… — AWS DocumentDB, MongoDB
          - wide column：workloads that require heavy r/w and high throughput，ms r/w — AWS Keyspaces, Hbase, Cassandra
          - graph：model complex networks (relationships & patterns) of objects, e.g. geolocation - social networks, fraud detection — AWS Neptune, Neo4j
          - time-series：store and query data associated with timestamps, e.g. IoT, application metric… — AWS Timestream
          - ledger：maintain a complete history of database changes — AWS QLDB
        - r/w speed*
          - 毫秒 ms millisecond = 千分之一秒 — 亚毫秒sub-millisecond = 不到毫秒
          - 微秒 µs microsecond = 百万分之一秒
          - 纳秒 ns nanosecond = 十亿分之一秒
    - SaaS
      - Content/file storage：文件形式的存储，如OneDrive
      - Information Storage and Management：数据通过web接口传入系统存于云应用，= SaaS服务模式的Database
      - 内容分发网络CDN
        - 源服务器将数据replicate至边缘节点服务器*N - 用户直接访问地理位置最近的节点服务器
          - 自建：大型企业-Netflix
          - CSP(免费/付费)：CloudFlare
        - 优：冗余负载、速度稍快-减少视频文件的跳数=更流畅、错峰使用、抗DDoS、作为WAF、省钱(免server+infra)
    - 存储容量管理：~ cost — 检查环境配置+使用情况 by Amazon Trusted Advisor、Azure Advisor
  - Management Plane：云资源管理
    - Cloud Portal，如AWS mgnt console — VM的资源配置、如RAM,存储
    - Orchestration，如AWS Systems Manager, Zapier — 基于IaC实现云环境管理 auto workflow(一组服务)，如VM reboot, patch 含provision automation allocation — 支持多云：CSPs之间管理并移动workloads
    - Scheduling，如AWS Instance Scheduler — 按计划运行某个服务 by tagging+实例调度器/函数 — tagging：如"Env: Prod"用来识别生产实例+设置7*24运行规则
    - 开源：Openstack云基础设施管理 + Cloudify应用自动化部署和编排
- 安全
  - 加密
    - 类型
      - Native CSP：交由CSP生成密钥+加密 — 劣：不安全
      - Bring Your Own Encryption (BYOE)：CSC在本地KMS(with HSM)生成密钥+加密数据 – 上传加密数据至云 客户端加密 client-side = remote key mgnt system — 多用于SaaS
      - Bring Your Own Key (BYOK)：CSC在本地KMS生成KEK\DEK – 上传DEK至Cloud KMS(with HSM) - CSP服务器调取DEK(不可见) - TDE(透明数据加密)数据库和存储 云端加密 server-side = local key mgnt system CSP同态加密 — KEK：用于加密DEK key encryption key data encryption key
    - 保护
      - TPM：常用 软件TPM / IoT集成TPM instead of 硬件TPM
      - CSP HSM，如AWS CloudHSM、Azure Dedicated HSM
      - CSP KMS，如AWS KMS, Azure Key Vault 密钥管理服务
    - key与data分开存：不在CSP DC > 放在CSC DC=需底层联通=贵、多用CASB管
    - Secret Sharing Made Short (SSMS)：a three-phase process Shamir's Secret Sharing简化版 / Threshold Secret Sharing
      - Secret Representation：加密数据 - 转换secret(key,data)为二进制字符串/比特序列便于分割
      - Bit Splitting：secret's bits 分割为 shares via via info dispersal algorithm (IDA) - shares 被 signed+dispersed to different Cloud storage services
      - Secret Reconstruction (Threshold Recovery)：收集 minimum number of shares (threshold) - 重构 secret
  - 云审计
    - CSC应关注logs
      - IaaS：CSP提供设备、网络层(DNS,端口,边界)、Hypervisor、云服务的API调用、billing records、console…
      - PaaS：应用层面，如输入/输出验证失效、身份验证/授权失效、会话管理、应用错误、重启、高风险操作、变更…
      - SaaS：CSP提供 web、应用、DB、使用、访问日志…
    - 难点：understand scope of cloud enviornment
    - CSP不允许CSC审计、但可提供审计材料
  - BC/DR
    - BIA新考量：依赖方(CSP)、数据合规性、内部人员、远程访问、Vendor lock-in/out
    - 备份
      - 传统DC运营、云上备份
      - 云上运营、花钱让CSP备份
      - 云上运营、花大钱让其它CSP备份
- 产品
  - 云访问安全代理CASB
    - 演化：云服务↑+BYOD↑+影子IT 》需统一管理 — 影子IT：员工使用未经授权的IT资源，如网盘 shadow/embedded/feral/stealth/hidden IT
    - 定义：控制所有终端对云服务/驻场系统的安全访问(身份验证+加密) — 厂商：McAfee, Cisco, Zscaler, Netskope — 部署：SaaS / 本地
    - 模式
      - 多模式：代理+API 常用
      - Proxy：user与cloud之间Inline部署、过滤全部流量后转发云应用
        - 前向代理：近user管控、CASB部署by user = 终端需安装VPN/EDR
        - 反向代理：近cloud管控、CASB部署by SaaS — 优：user无限制=访问快、适用BYOD
      - API：Out-of-Band部署、管控用户的SaaS操作权限 — 劣：各SaaS API管控无法通用
    - 特征
      - 可见性：谁通过什么设备 在哪儿 怎么访问了云服务
      - 数据安全：DLP Lite版
      - 威胁防护：自适应访问控制 + 最新TI检测攻击
      - 合规：基于法规要求进行基线检测
    - 步骤
      - 1.发现：自动生成第三方云服务+使用人清单
      - 2.分级：基于应用内容|数据|共享模式等 确定风险等级
      - 3.整改：生成安全策略+异常告警
  - 云工作负载保护平台CWPP 2010
    - 定义：检测云/本地的工作负载威胁 — 工作负载：承载计算的节点，包括服务器, VM, 容器, Vault, 服务资源等
    - 优：不安全的负载检测(漏洞, 恶意软件, EDR, IDS)、运行时保护(FIM, 日志检查, 应用白名单控制)、网络微隔离
    - 劣：需为每个资产部署代理(影响性能,成本,OS兼容)、缺少Control Plane、无告警优先级(缺上下文)、无法阻拦横向攻击(无法识别access key)
  - 云安全态势管理CSPM 2014
    - 定义：检测云的错误配置
    - 优：强制安全策略、多云统一配置管理via Control Plane (识别云资产)、可集成CSP检测工具(与DevOps集成自动修复, 与SIEM集成威胁检测)
    - 劣：缺少工作负载监控、无告警优先级(缺上下文)、无法阻拦横向攻击
    - *云基础架构安全状态评估CISPA：第一代CSPM、仅报告配置错误
  - 云基础设施授权管理CIEM 2018
    - 定义：帐号权限异常检测 for 公有云,多云的最小特权
    - 优：IAM、审计多云访问权限、集成IdP(SSO)、提供授权建议
    - 劣：不完整的IAM(识别SSH密钥, 横向攻击风险)、缺少Control Plane和负载监控
  - 云原生保护平台CNAPP 2020
    - 定义：集成DevOps+CIEM+CSPM+CWPP
    - 优：云攻击路径分析=有告警优先级、无代理部署=全负载可视化
  - SaaS管理平台SMP
    - 定义：集中管理SaaS
    - 优：SaaS应用发现、集中管理(访问控制,安全)、影子IT发现(同CASB)
  - SaaS安全态势管理SSPM — 定义：检测SaaS配置错误、冗余用户/权限等
- 风险
  - OWASP云原生应用安全Top 10 2022
    - 1.不安全的云、容器或编排配置 — 2.注入漏洞（应用层、云事件、云服务）
    - 3.身份认证和授权不当 — 4.CI/CD管道和软件供应链缺陷
    - 5.不安全的密钥存储 — 6.过度宽松或不安全的网络策略
    - 7.使用有已知漏洞的组件 — 8.资产管理不当
    - 9.未对容器或者pod资源进行有效限制 — 10.未能有效的进行日志记录和监控 (如运行时活动)
  - CSA 云计算的11个顶级威胁 2022
    - 1.身份,凭证,访问,密钥管理的不足 — 2.不安全的接口,API
    - 3.配置不当,变更控制不足 — 4.缺云安全架构,战略
    - 5.不安全的软件开发 — 6.不安全的第三方资源
    - 7.系统漏洞 — 8.无意的数据泄露
    - 9.无服务器和容器的配置不当 — 10.有组织的犯罪,APT
    - 11.云存储数据泄露：敏感信息，由于攻击/错误
  - IaaS
    - VM 攻击
      - VM escape：利用漏洞(VENOM) 渗透VM - 入侵其它VM 逃逸
        - Guest escape：入侵Host OS
        - Host escape：入侵Host所在网络的其它Host
      - VM sprawl：被遗忘的废弃的VM 蔓延 — *Server spawl：未被使用的服务器《 如大量采购低端服务器
      - VM之间/VM与主机之间 剪切复制粘贴：绕过IDPS检测 = 隐蔽通道 — TypeII产品 提供GPU use, shared clipboard, drag'n'drop between VM and Host
      - 防 - VM instance Isolation：by Hypervisor, NSG, ACL, Firewall, Resource(cpu memory disk)
    - Hypervisor攻击：一旦被入侵，承载的所有VM均危险
    - DoS：一个VM受攻击=所有VM资源受限、其它VM发起攻击
    - Co-location：VM镜像 vs 实体服务器 -攻击后- 镜像无法单独隔离 vs 实体可关机隔离
    - Network Security：虚拟隔离+主要依赖访问控制 vs 物理隔离+尽情部署网络监控产品
    - Virtual network、VM-based rootkits、Virtual switch attack

Presented with xmind